拾光书店 Web 实验报告

第二阶段 · 第 7—9 周 · Web v1.0 · 2026-11-09

0 文档信息与摘要

项	内容
版本	Web v1.0
日期	2026-11-09
提交	`663b959` 及后续修复分支
环境	Windows · PowerShell 7.6.5 · Python 3.14.2 · Flask 3.1.3 · pyodbc 5.4.0 · ODBC Driver 17 · SQL Server 17.0.1000.7 · Edge 156
范围	第 7—9 周 Web 构建；第 5—6 周设计与迁移只给路径

摘要：把已冻结的 21 个经营实体落实到顾客、收银员、库管、店长四类角色的 Web 操作；页面经路由、服务、DAO 调用存储过程，事务、权限与幂等由数据库过程最终把关。全量 119 项测试、16 个浏览器节点与 22 个结构反例通过；第 5—6 周内容见 §2。

1 实验目标与范围

本阶段回答三个问题：

1. 已冻结的数据模型如何映射为四类角色的页面，才能让角色只做该做的事，而权限不只藏在界面里？
2. 下单、取货、退款、采购等跨表写入，如何保证全成或全不成、重复提交不重复记账？
3. 四角色流程、异常路径与空环境复现，如何用可复核的证据证明？

范围只覆盖第 7—9 周 Web；第 5—6 周的 ER、范式、迁移与回归不在本文重复。

2 前置基线（第 5—6 周结果路径）

内容	路径
ER 图（19 实体历史基线）	`ER/er-diagram-v1.4.drawio` 与 `.png`；设计说明见 `docs/design/design-notes-v1.0.md`
业务规则与映射清单	`docs/design/er-mapping-v1.0.md`
v0.1 问题清单与结论	`docs/design/issues-v0.1.md`
范式、迁移与回归	`docs/design/design-normalization-v1.0.md`；`docs/reports/report-week-6.md`
第 6 周验收与原始输出	`docs/reviews/review-week-6.md`；`db/results/week-6/`
本文使用的 21 实体	`docs/design/web-model-extension.md`；`ER/er-diagram-web-v1.0.png`

3 Web 设计

3.1 技术选型与约束

选择 Flask 3.1.3 + Jinja2 + pyodbc 5.3.0（SQL Server 17、ODBC Driver 18），不引入 ORM：项目只有 21 个实体、以存储过程承载事务，ORM 的反向建模与自动迁移会与已冻结的库结构冲突。数据库金额列用 `DECIMAL`，关键金额校核（注资、提现、卡参数）用 `Decimal`；页面金额大多为两位小数，采购单金额仍显示四位小数（待统一）。时间字段按数据库本地值展示，运行日志用 UTC，未实现跨时区转换；配置与密钥外置到 `run.*.json` 与设置目录，不写入代码。

三条禁止项：路由与业务层不得拼接 SQL；不得用字符串格式化拼参数；不得绕过 DAO 直接连接数据库。

3.2 总体架构

```
浏览器（HTML 表单 / JSON API）
   │ 会话 + CSRF
Blueprint 路由（读输入、取当前身份）
   │
业务服务（预览、确认、流程编排）
   │
DAO（唯一 SQL 出口，? 参数绑定）
   │ EXEC api.usp_*
存储过程（岗位复核、锁、事务、规则）
```

```
    |
SQL Server (21 实体 / 六类受限账户)
```

调用方向单向，页面层不直接访问表；业务层不持有 SQL；事务由存储过程持有。整体是**薄应用、厚数据库**：应用负责输入、身份与流程编排，规则、锁与原子写入下沉到过程。写路径经"路由→服务→DAO"；只读查询在鉴权后直接调用 DAO，不经服务层（当前实现的已知简化）。请求处理路径的 SQL 只在 `app/dao.py`；建库、授权与升级由 `app/manage.py`、`provision_local.py`、`upgrade_guest.py` 等 CLI 脚本执行。

3.3 角色与页面清单

角色	输入与操作	结果与边界
顾客	浏览在售商品，提交预订，凭手机号+预定码查询/取消；会员用凭证自助查询	只访问公开资料与本人凭证；不见内部编码、成本、全店单据
收银员	新建销售清单、预览、确认收款；取货；退款；会员办理	只处理本人单据；不能定价、审批、看盈亏
库管	商品建档、供应商与报价、采购草稿/提交/收货、报损、退货回收	负责实物与库存流水；不能定价、付款、看经营报表
店长	定价与上下架、审批付款、注资/提现、卡参数、员工、全店单据与报表	可见经营信息，但不代替收银收款、不代替库管收货

页面清单：

路径	角色	用途
`/shop`、`/shop/goods/<id>`	顾客	商品列表与详情
`/shop/reservations/new`、`lookup`、`receipt`	顾客	预订、查询、凭证
`/shop/member`	顾客（凭证）	会员自助
`/auth/login`、`/auth/logout`、`/workspace`	公共/员工	登录、登出、工作台
`/sales/new`、`/sales`、`/sales/<no>`	收银员	销售清单、列表、凭证
`/pickups`、`/returns/new`、`/members`	收银员	取货、退货、会员
`/goods`、`/suppliers`、`/supplier-quotes`	库管	商品、供应商、报价
`/purchases`、`/purchases/<id>`、`/inventory`、`/return-recovery`	库管	采购、库存、回收
`/management/{goods,finance,employees,cards,reports,sales,returns,reservations}`	店长	定价、资金、员工、卡参数、报表、全店单据

角色 × 动作矩阵：

动作	顾客	收银员	库管	店长
浏览/预订/查询本人凭证	✓	—	—	—
销售/取货/退款/会员办理	—	✓	—	—
商品/供应商/采购/收货/报损/回收	—	—	✓	—
定价/审批付款/员工/卡参数/报表	—	—	—	✓
全店单据查看	—	—	—	✓

3.4 接口清单与契约

接口组	方法/路径	角色	输入	输出	主要错误
登录	`GET/POST /auth/login`、`POST /auth/logout`	公共/员工	手机号、口令、CSRF	302 到工作台；会话	400/401/403

接口组	方法/路径	角色	输入	输出	主要错误
顾客目录	`GET /shop`、`/shop/goods/<id>`	顾客	关键词、分类、分页	HTML 列表/详情	400/404
预订	`POST /shop/reservations`、`POST /shop/reservations/cancel`	顾客	手机号、明细、预定码	303 凭证；HTML	400/404/409
预订查询	`POST /shop/reservations/lookup`	顾客	手机号+预定码	凭证页	404
销售	`GET /sales`、`GET /sales/<no>`、`POST /sales/cart`、`/sales/preview`、`/sales`	收银员	明细、会员、积分、请求键	预览页/凭证；303	400/403/409
取货	`POST /pickups/preview`、`/pickups`、`/pickups/cancel`	收银员	手机号、预定码、积分	预览/销售凭证	404/409
退货	`POST /returns/preview`、`/returns`、`/return-recovery`	收银员/库管	原单号、行、数量	退款凭证/回收结果	400/404/409
会员	`POST /members/preview`、`/members`、`/members/contact`	收银员	手机号、档位、联系方式	收费页/凭证	400/409
经营动作	`POST /operations/<action>`、`/operations/<action>/preview`、`/operations/confirm`	库管/店长	动作参数、请求键	303 回列表；预览	400/403/409
JSON API	按资源命名：`/api/sales`、`/api/sale-goods`、`/api/shop/*`、`/api/pickups/*`、`/api/operations/*`	对应角色	JSON + `X-CSRF-Token`	`{"error":...}` 或数据	同上

响应约定：销售、预订与经营动作成功后用 303 跳转结果页；登录用 302 跳工作台；会员办理成功后直接渲染凭证页（POST 返回 200）。API 成功返回数据，失败返回统一错误体；响应头带 `X-Request-ID`。写动作必须带 CSRF（表单隐藏域或 `X-CSRF-Token`）与请求键；同键同内容重放返回原结果，同键异内容返回 409。

成功响应示例（API）：

```
{"sale_no": "W7S20261107-001", "paid_amount": "18.05", "request_id": "..."}
```

错误响应示例（API）：

```
{"error": {"code": "insufficient_stock", "message": "可售量不足，请调整数量后重新预览。"}, "request_id": "..."}
```

HTML 页面：销售/预订/经营动作成功 303 → 结果页，会员办理成功直接渲染凭证页（200）；失败渲染错误页，显示状态码、可纠正提示与请求编号。分页要求页码 ≥1、页长不超过上限，超限统一返回 400。

3.5 权限与数据可见性

权限分三层：菜单按岗位隐藏；后端每个写动作独立复核身份与数据范围；数据库用 `auth`、`cashier`、`inventory`、`manager`、`guest`、`task` 六类受限连接，关键过程再查岗位。角色 × 动作矩阵见 §3.3。

身份	用途	不能做
`auth`	登录、会话校验	业务写入
`cashier`	销售、取货、退货、会员	采购、定价、报表
`inventory`	商品、供应商、采购、库存、回收	销售收款、定价、盈亏
`manager`	审批付款、定价、员工、报表	代替收银/库管操作
`guest`	公开目录、预订、凭证查询	任何员工表与全店数据
`task`	到期释放	人工操作

字段级可见性示例：顾客看不到内部编码与采购价；收银员看不到批次进价与盈亏；库管看不到经营报表；店长可见经营数据，但不自动获得其他岗位的操作权。

3.6 认证与会话

登录用手机号+口令，口令以 Werkzeug 哈希存储；成功后写入 `actor` 与 CSRF token，会话 8 小时。每次请求校验 CSRF，写动作缺失或错误时返回 403。会话中带 `session_version`，员工改岗、停用或重置口令后版本递增，旧会话下一次请求即失效（401）。Cookie 设置 `HttpOnly`、`SameSite=Lax`，`Secure` 由环境变量控制。

3.7 事务、并发与幂等

预览与确认分离：预览只读、不占长事务；确认在新事务中复核身份、状态、金额与配置。一次业务由一个存储过程持有一个事务，典型包括：销售（单头+明细+库存+积分+资金）、取货（预订释放+销售+库存）、退款（退款+积分回滚）、采购付款与收货、报损、会员办理。各流程内部有固定锁顺序：销售为配置→商品（按 ID 升序）→资金；退款为原单→会员→资金；回收为退货明细→商品。跨流程不共用同一组资源，未做全局统一排序。

幂等由"可信主体 + 动作 + 请求键 + 内容摘要 + 原结果"实现：同键同内容返回原结果，同键异内容拒绝；成功记录与业务写入同事务。

3.8 异常处理与日志

HTTP	业务错误码示例	场景
400	`52101`、`52301`、`52501`	参数、数量、格式、分页超限
401	认证	未登录、会话失效
403	`52003` / CSRF	岗位不足、CSRF 无效
404	`52108`、`52304`、`52504`	单据/记录不存在，或无权获知
409	`52103`—`52107`、`52302`—`52309`、`2601/2627/547`	库存不足、状态冲突、资金不足、预览过期、唯一/外键/CHECK
503	连接失败	数据库不可用
500	未预期	未捕获异常、事务失败
405/415	协议层	方法不允许、媒体类型错误

用户可见信息只给"可纠正的一句话 + 请求编号"，不出现 SQL、表名、约束名、连接串、堆栈。运行日志的 8 个核心字段是 `request_id / time / action / role / status / error_code / result / duration_ms`，另附 `method / subject_type / subject`（主体用 HMAC 脱敏）；业务留痕（改价人、收货人、退款人等）落在业务表，不与运行日志混用。

3.9 页面交互与校验

前端做必填、格式、范围的基础校验，后端仍以服务与过程为准；按类别显示对应字段（图书/文创），不把无关字段一起提交。列表空状态给明确文案；删除、退款、取货等不可逆动作二次确认；错误提示在字段旁或页头，409 提示"重新预览"，503 提供"重试"。

4 Web 实现

4.1 模块与文件结构

目录/文件	职责
app/routes/	蓝图：认证、工作台、销售、经营动作
app/shop.py、reservations.py、returns.py、members.py、management.py	顾客、预订、退货、会员、店长页面
app/services.py、sales.py	身份、会话版本、预览/确认、业务编排
app/dao.py	唯一 SQL 出口：连接选择、参数绑定、结果转换、错误映射
app/templates/、app/static/	页面与脚本
app/expiry.py	独立到期任务
db/*-entry.sql	存储过程、授权与运行时对象

设计→实现映射（示例）：

§3 设计	实现落点
3.2 总体架构	写路径 app/routes/* → app/services.py → app/dao.py → api.usp_*；只读查询鉴权后直达 DAO
3.3 角色页面	各蓝图与模板；/management/<kind> 分派
3.4 接口契约	app/web.py 错误/日志处理；路由返回 303/302 或 JSON
3.5 权限三层	app/dao.py 连接身份；过程内岗位复核
3.6 认证会话	app/routes/auth.py；app/web.py CSRF 与版本校验
3.7 事务幂等	api.usp_sale_create 等过程；api.operation_request

4.2 请求处理与调用链

查询：本人销售单

```
GET /sales
 → 路由读取会话 actor，校验岗位，解析分页参数
 → EmployeeDAO.sale_list(actor, page, page_size)   ← 只读查询直接调 DAO，不经服务层
 → EXEC api.usp_sale_list @employee_phone=?, @page=?, @page_size=?
 → 过程按收银员过滤并分页
 → 模板渲染列表
```

写入：创建销售

```
POST /sales（CSRF + 签名引用 + 请求键）
 → SalesService.create 校验签名、主体、动作
 → EmployeeDAO.sale_create(actor, key, payload, expected)
 → EXEC api.usp_sale_create …
 → 事务由该过程持有：复核库存、权益、金额，写单头/明细/库存/积分/资金
 → 303 到 /sales/<no> 凭证
```

4.3 关键流程实现

采购付款与收货。 店长先注资；库管建草稿、提交；店长审批并付款；库管整单收货。付款只产生资金流水，收货才增加库存，两个动作各有操作人与单据来源。

预订取货。 顾客提交预订后生成预定码与到期时间；收银员核验后按会员折扣结算，生成销售单并把预订置为已取；取消或到期只释放已订量，不产生销售。

退款与回收。 收银员按原单选择行与数量，按差分公式计算退款并回滚积分；退款不直接加库存，库管确认回收后才写退货入库流水。

流程	事务边界	锁对象	幂等键	失败行为
采购付款	一次付款一个事务	资金行（UPDLOCK）；采购单按状态复核	请求键 + 内容摘要	回滚，不产生半笔资金
采购收货	一次收货一个事务	商品行（UPDLOCK）；采购单按状态复核	请求键	回滚，库存不变
取货	预订释放+销售+库存同一事务	会员/配置、商品（ID 升序）、预订行	确认凭据 + 请求键	回滚，预订仍有效
退款	退款+积分回滚同一事务	原销售单（UPDLOCK）、会员、资金行	请求键	回滚，不产生半笔退款
回收	一次回收一个事务	退货明细（UPDLOCK）、商品	请求键	回滚，库存不变

SQL 对账	实际结果
采购 2 件 × ¥5.00	已收货，库存 +2，资金只付一次
销售 1 件，银卡 0.95	原价 ¥19.00，实收 ¥18.05，库存 −1
退款 1 件	退回 ¥18.05，积分回滚 18；回收后库存 +1

修改与删除边界。 采购草稿与待结算清单可改；成交后走退货冲销；库存差异走收货、回收、报损，保留来源。商品仅在零库存、未上架、五张引用表均无记录时可删；删除同步清理图书/文创子类档案，编码可复用。

4.4 权限、会话与异常的落地

路由统一从会话取 `actor`（`g.request_actor`，`app/web.py:48`），写动作由 `services.current_actor` 复核岗位与数据范围；项目没有单独的鉴权装饰器，身份校验集中在请求前处理与服务入口。DAO 按动作选择连接身份（`cashier`/`inventory`/`manager`/`guest`/`task`），过程再校验一次。CSRF 在 `app/web.py` 的 `before_request` 统一校验；会话版本在每次请求与员工变更时比对。错误由 `AppError` 统一映射为状态码与业务码（`app/web.py` 错误处理器）；页面错误页与 JSON 错误体共用请求编号；`after_request` 写请求日志并回填 `X-Request-ID`。

4.5 后台任务与运行配置

`app/expiry.py` 独立进程运行（`python -m app.expiry`），默认 60 秒一轮，只连接 `task` 身份并调用到期过程；取货等入口仍即时判断到期，不依赖扫描。运行配置由 `run.example.json` 生成本地 `run.*.json`；`setup` 在 `<settings_directory>` 下生成六组连接、`settings.local.ps1` 与 `demo-credentials.local.json`。`run.ps1 start` 拉起 Web 与任务，`stop` 结束并释放端口。

4.6 实现顺序与返工

按 P0 基线补齐 → P1 公共基础 → P2 商品与采购 → P3 预订取货 → P4 会员 → P5 退货与经营 → P6 交付推进。返工至少三次：

1. 索引数量校验写死为 6，Web 新增第 7 个筛选唯一索引后从零建库失败，改为按索引名与启用状态校验；
2. 历史归档按字节指纹审计，Git 换行转换导致校验失败，用 `.gitattributes` 固定检出换行；
3. 删除商品只删主表，子类表残留导致同编码无法重建，改为同事务清理子类。

5 运行结果与截图

5.1 运行环境

Windows、PowerShell 7.6.5、Python 3.14.3、Flask 3.1.3、pyodbc 5.x、ODBC Driver 18、SQL Server Express 17.0.1000.7、Chrome（Playwright 驱动）。截图演示库 `ShiguangBookstoreWeek7Shots20261109`，端口 5097；测试库与演示库相互独立。

5.2 启动与复现命令

前置条件

项	要求
系统	Windows 10/11，PowerShell 7+
数据库	SQL Server Express 2019+，启用 SQL 登录；当前可用实例 `localhost\SQLEXPRESS`
Python	3.12+，已安装 `requirements.txt` 依赖（Flask、pyodbc 等）
驱动/工具	ODBC Driver 17 或 18；`sqlcmd` 可用
其他	一个空闲端口；对实例有建库与建登录权限的 Windows 账户

本地配置

```
Copy-Item run.example.json run.local.json
```

`run.local.json` 不提交，至少修改以下字段：

字段	示例	约束
`server`	`localhost\SQLEXPRESS`	实际实例
`driver`	`ODBC Driver 18 for SQL Server`	本机已安装
`database`	`ShiguangBookstoreWeek7MyDemo`	**必须以 `ShiguangBookstoreWeek7` 开头**，且为新库名
`login_prefix`	`bookstore_mydemo`	小写、唯一；每个库用不同前缀
`port`	`5098`	未被占用
`settings_directory`	`.runner/mydemo/settings`	可写，已 gitignore

执行顺序

```
$config = 'run.local.json'
./run.ps1 setup  -ConfigFile $config   # 首次：建库、建登录、生成设置与演示凭据
./run.ps1 doctor -ConfigFile $config   # 只读诊断
./run.ps1 test   -ConfigFile $config   # 全量 119 项
./run.ps1 start  -Detach -ConfigFile $config
./run.ps1 status -ConfigFile $config
./run.ps1 verify -Http -ConfigFile $config
./run.ps1 stop   -ConfigFile $config
```

每步预期

步骤	预期
`setup`	29 步 PASS；输出运行目录与 `demo-credentials.local.json` 路径
`doctor`	6 项 PASS（依赖/实例/基线/权限/运行时/对象）
`test`	119 通过，失败 0、错误 0、**跳过 0**
`start`	打印 web/expiry PID 与日志目录；端口开始监听
`status`	`status=running`，两个进程均有 PID
`verify -Http`	`verify` 与 `verify-http` 双 PASS
`stop`	两个进程结束，端口释放

常见问题

现象	处理
`setup` 报对象/索引不符	换新的 `database` 与 `login_prefix`，不要复用旧库
`test` 出现 skip	六组连接未生成或 settings 未加载；重新 `setup` 或检查设置目录
端口被占用	先 `stop`，或改 `port`
`stop` 后进程残留	再执行一次 `stop`；仍残留时按 PID 手工结束（已知兜底）
任何步骤失败	先看 `.runner/<运行>/summary.json` 与同目录 `web.log`、`expiry.log`

> 上述命令已在**全新 5099 配置**（`run.check.json`，库 `ShiguangBookstoreWeek7CheckFinal20261109`，与 `run.local.json` 等价）上逐条执行：`setup` 29 步 PASS、`doctor` 6 项 PASS、`test` 119 项通过（失败/错误/跳过均为 0）、`start -Detach` 成功、`status=running`、`verify -Http` 双 PASS、`stop` 后端口 5099 释放。

演示员工账号（本机 5097 演示库）：

角色	姓名	账号（手机号）	口令
店长	林泽群	`13800000001`	`Demo!2e6mPQE9LivDIoTf0EmEbvLi`
库管	黄智亮	`13800000002`	`Demo!Q-9kBSfuYthPcCionX0ofSR8`
收银员	梁宇聪	`13800000003`	`Demo!dLr7OdRkMWtQagzdS22WRecD`

角色	姓名	账号（手机号）	口令
收银员	陈思远	13800000004	Demo!mXfc8ztqNGPU6AOftat-x5sq

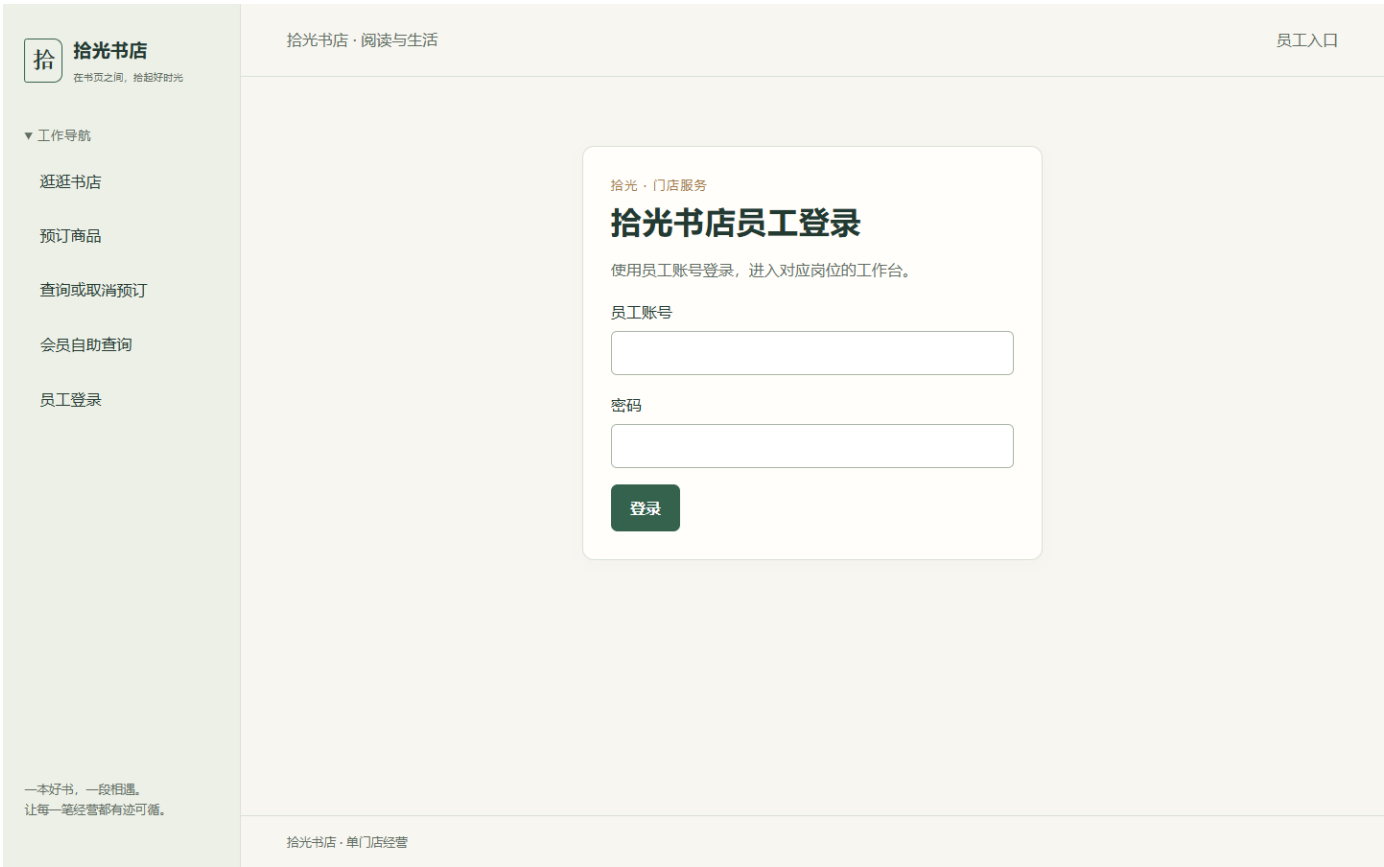
> 口令由 `setup` 随机生成，仅对应该演示库；换环境后以 `<settings_directory>/demo-credentials.local.json` 为准。报告外发前应重置口令或删除本表。

5.3 截图范围与原则

共 26 张功能截图：入口层 5、操作层 8、结果层 13；图号 1—26，全部正文内嵌。异常截图（图 27—32）统一放 §6。同一页面只保留能证明不同结论的状态；演示数据为虚构，截图未统一打码，外发前需遮盖手机号与凭证。

5.4 逐图说明

入口层（5）



> 图 1 | 日期/库/端口：2026-11-09，ShiguangBookstoreWeek7Shots20261109，5097 | 公共·登录页 | 前置：无 | 操作：打开登录页 | 预期：显示账号与口令表单 | 实际：200，表单可用



图 2｜日期/库/端口：2026-11-09，ShiguangBookstoreWeek7Shots20261109，5097｜顾客·/shop｜前置：匿名｜操作：打开商品列表｜预期：只显示上架且有价商品｜实际：在售商品正常显示

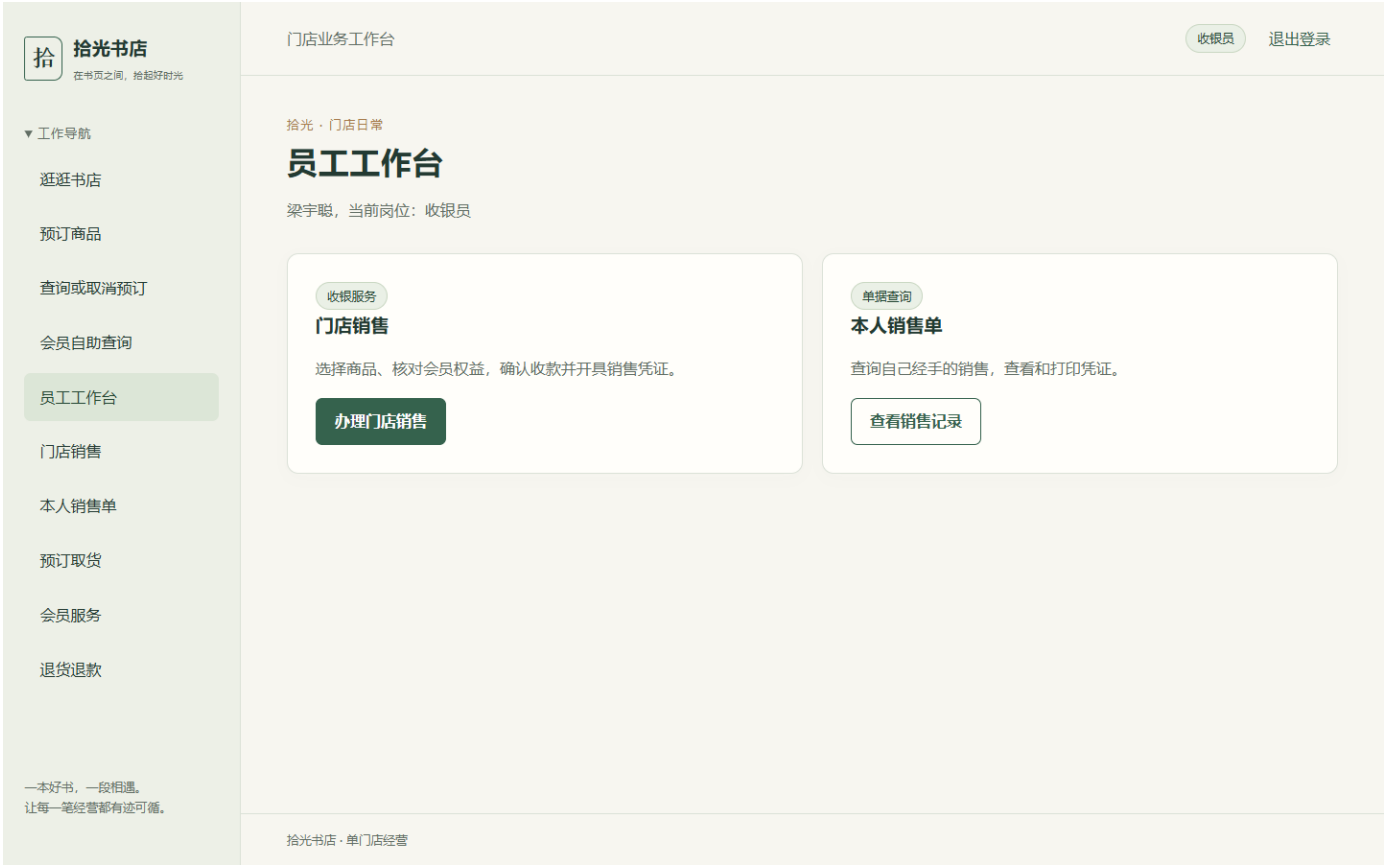
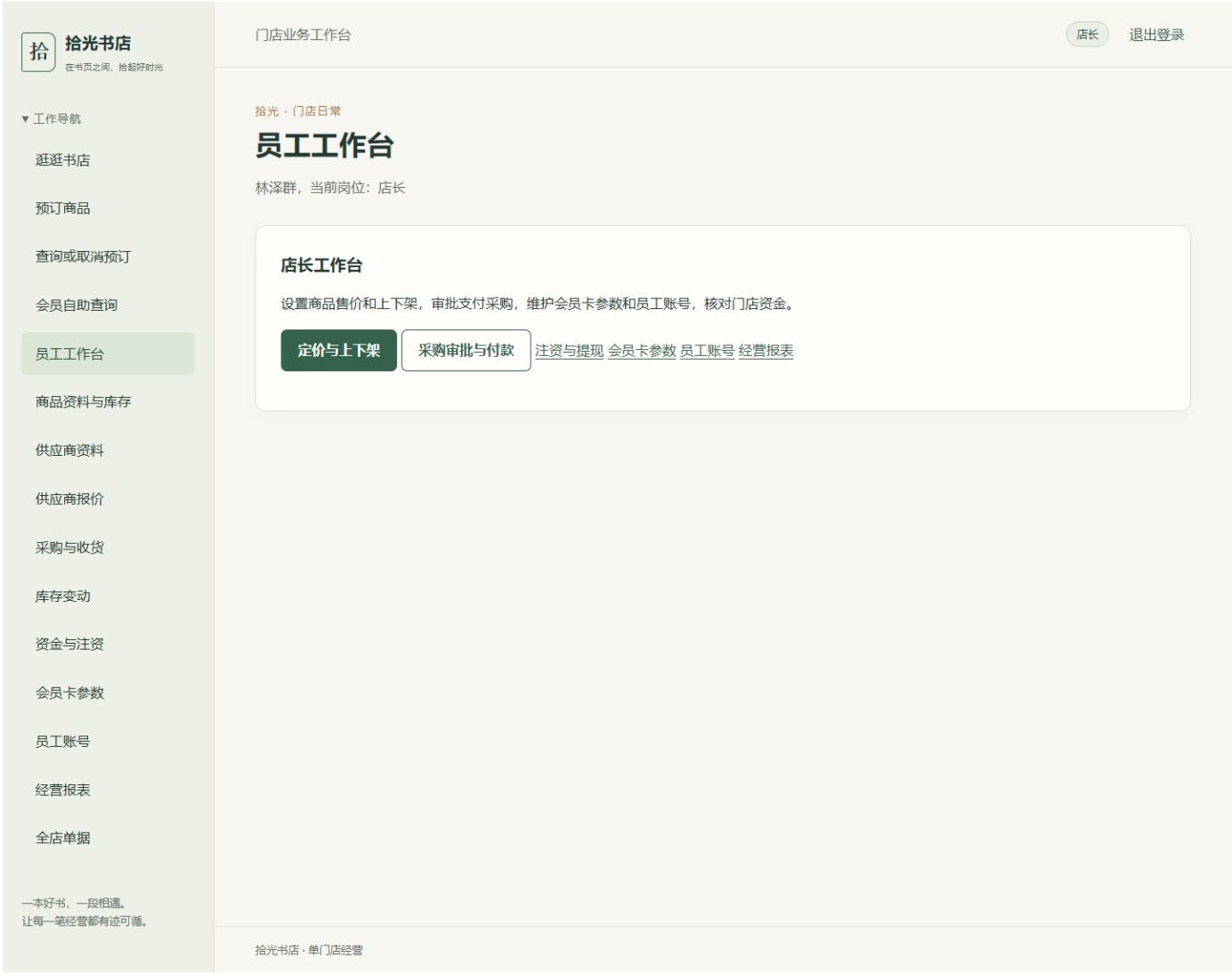


图 3 | 日期/库/端口：2026-11-09，ShiguangBookstoreWeek7Shots20261109，5097 | 收银员·工作台 | 前置：收银登录 | 操作：打开工作台 | 预期：销售/取货/退货/会员入口 | 实际：入口齐全



图 4 | 日期/库/端口：2026-11-09，ShiguangBookstoreWeek7Shots20261109，5097 | 库管·工作台 | 前置：库管登录 | 操作：打开工作台 | 预期：商品/采购/库存/回收入口 | 实际：入口齐全



> 图 5 | 日期/库/端口：2026-11-09，ShiguangBookstoreWeek7Shots20261109，5097 | 店长·工作台 | 前置：店长登录 | 操作：打开工作台 | 预期：定价/资金/员工/报表入口 | 实际：入口齐全

操作层（8）

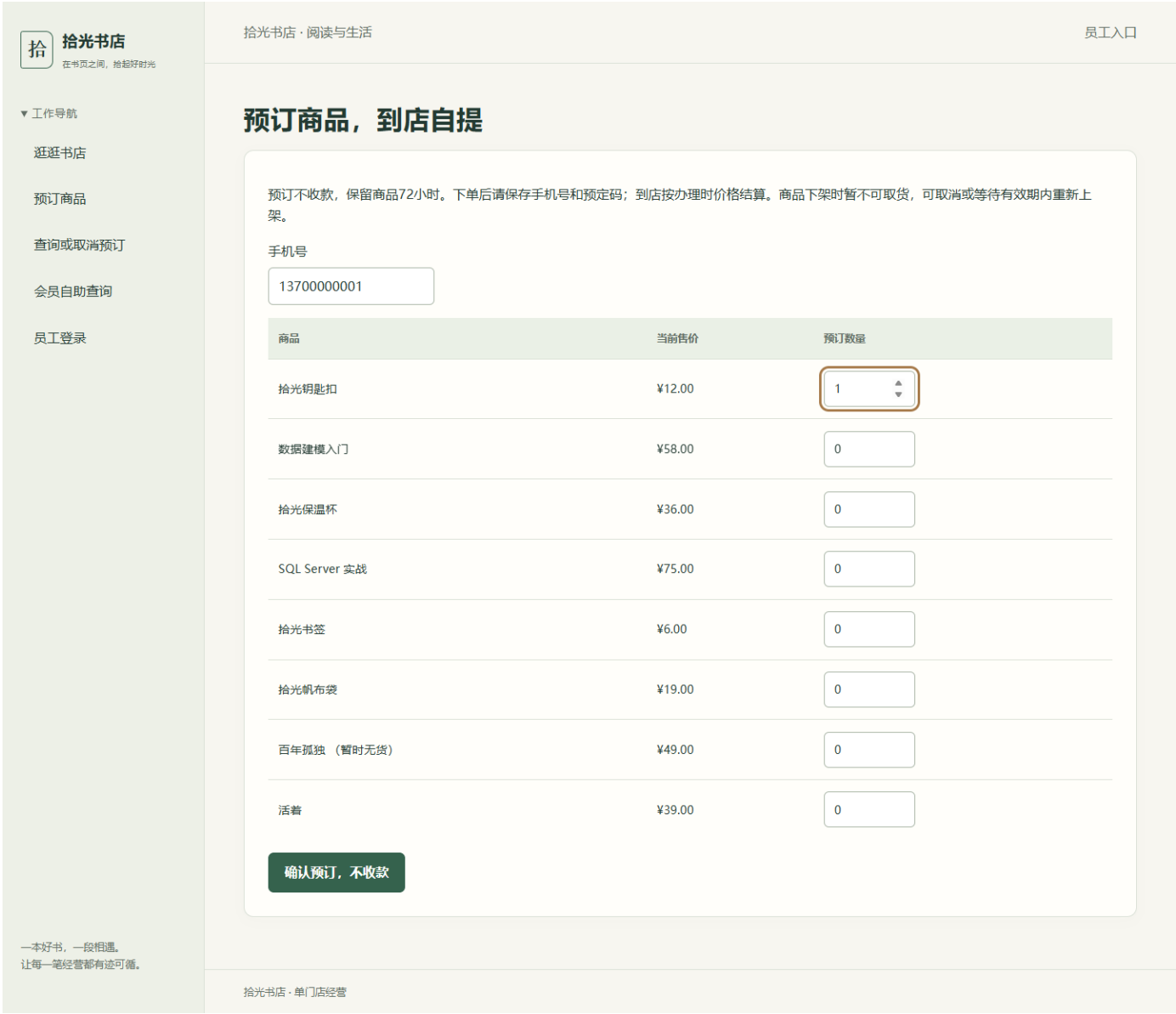


图 6 | 日期/库/端口：2026-11-09，ShiguangBookstoreWeek7Shots20261109，5097 | 顾客·预订表单 | 前置：无 | 操作：手机号 13700000001、1 件 | 预期：保留 72 小时、不收款 | 实际：生成预定码



图 7 | 日期/库/端口：2026-11-09，ShiguangBookstoreWeek7Shots20261109，5097 | 收银员·销售预览 | 前置：1 件 ¥19.00、银卡 0.95 | 操作：预览结算 | 预期：应收 ¥18.05 | 实际：应收 ¥18.05

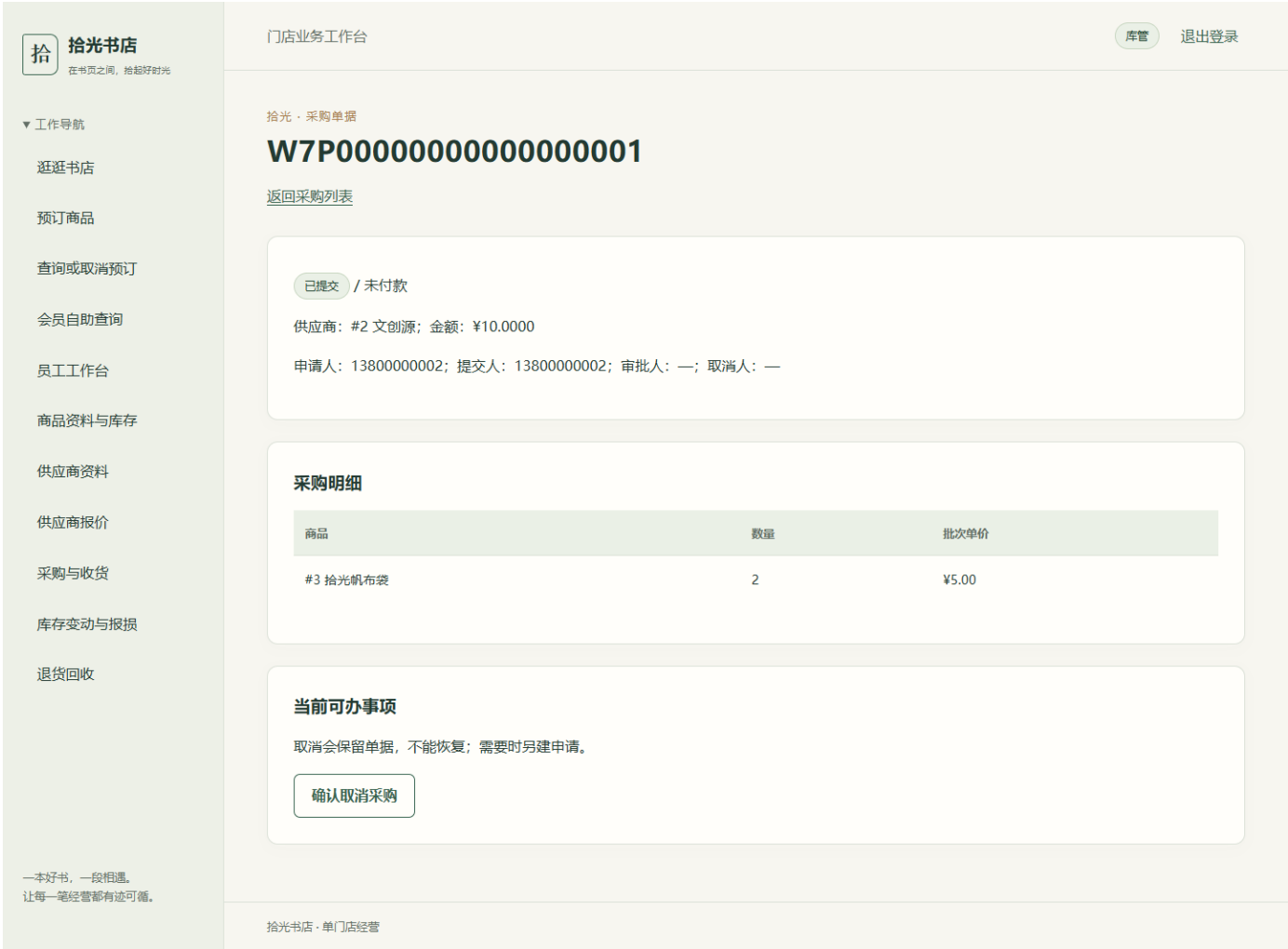


图 8 | 日期/库/端口：2026-11-09，ShiguangBookstoreWeek7Shots20261109，5097 | 库管·采购提交 | 前置：草稿 2 件 × ¥5.00 | 操作：确认提交 | 预期：状态已提交 | 实际：W7P...01 已提交

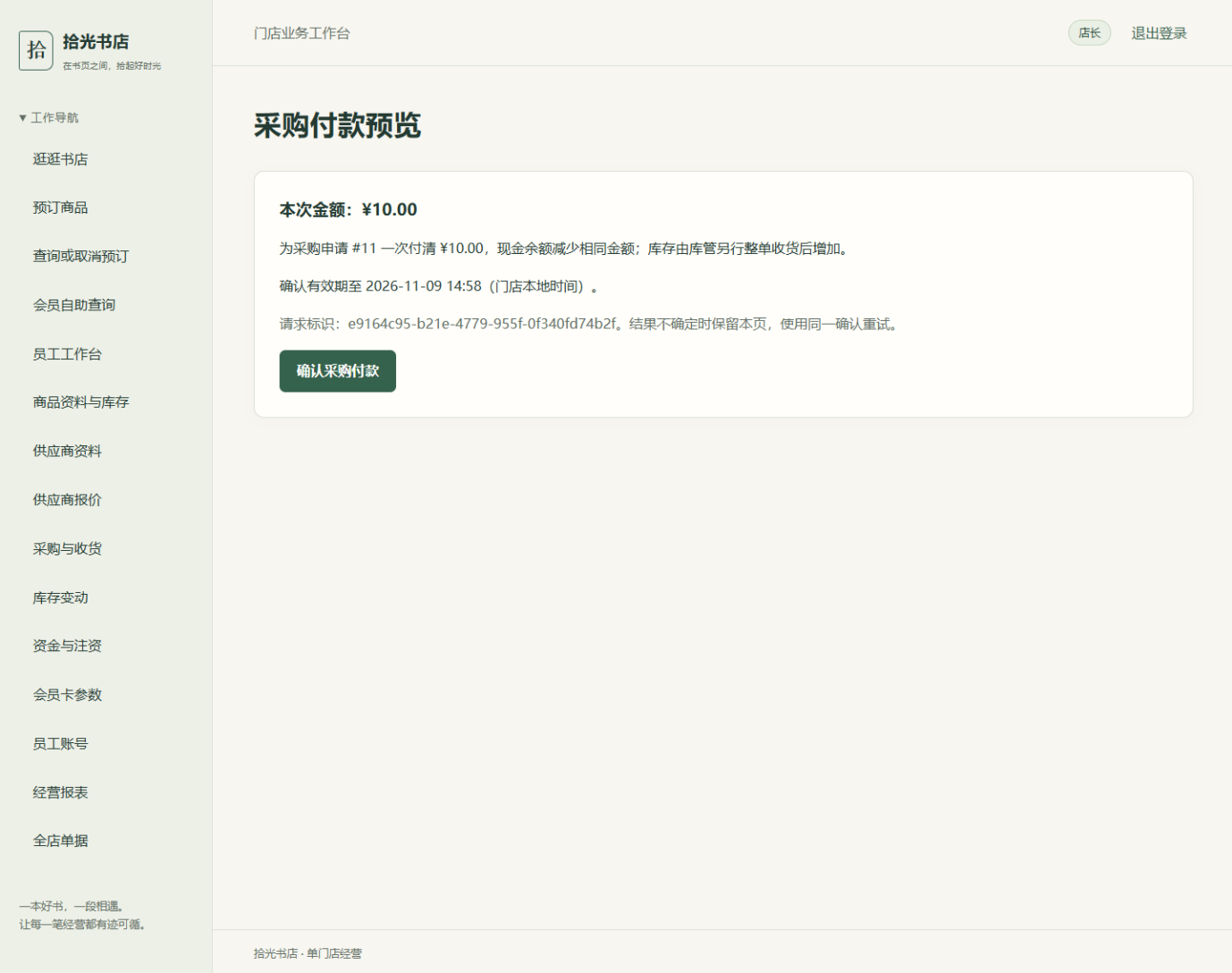


图 9 | 日期/库/端口：2026-11-09，ShiguangBookstoreWeek7Shots20261109，5097 | 店长·审批与付款预览 | 前置：采购已提交 | 操作：审批→预览付款 | 预期：¥10.00、限时有效 | 实际：金额 ¥10.00

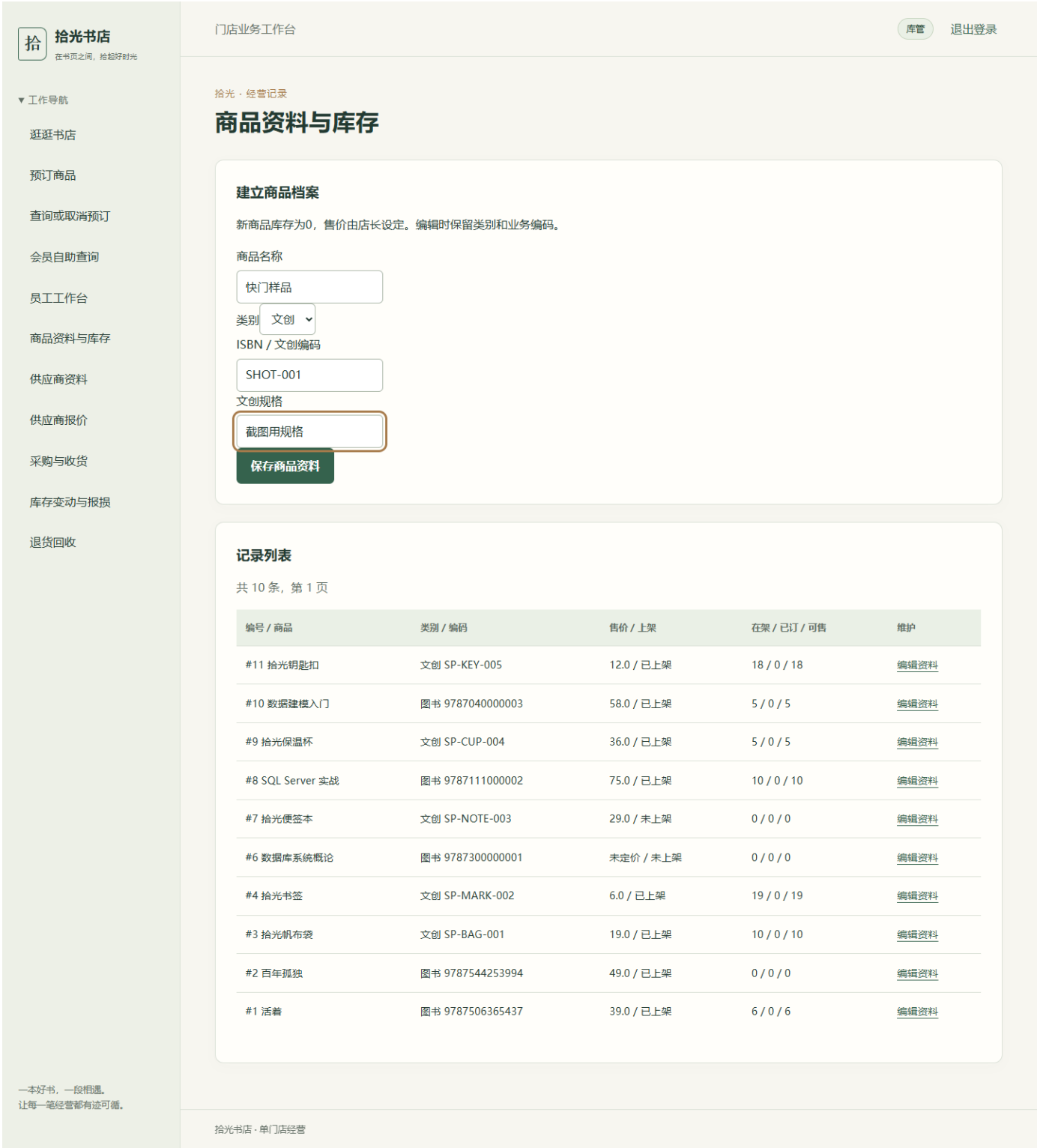


图 10 | 日期/库/端口：2026-11-09，ShiguangBookstoreWeek7Shots20261109，5097 | 库管·商品建档 | 前置：无 | 操作：填文创 SHOT-001 与规格 | 预期：表单校验通过后保存 | 实际：表单已填、尚未提交（截图后保存成功）



图 11 | 日期/库/端口：2026-11-09，ShiguangBookstoreWeek7Shots20261109，5097 | 库管·供应商报价 | 前置：两家供应商 | 操作：打开报价页 | 预期：列表可见 | 实际：200

拾光书店
在书页之间，拾起好时光

▾ 工作导航

- 逛逛书店
- 预订商品
- 查询或取消预订
- 会员自助查询
- 员工工作台
- 商品资料与库存
- 供应商资料
- 供应商报价
- 采购与收货
- 库存变动
- 资金与注资
- 会员卡参数
- 员工账号
- 经营报表
- 全店单据

一本好书，一段相遇。
让每一笔经营都有迹可循。

门店业务工作台 店长 退出登录

拾光 · 经营记录

商品资料与库存

记录列表

共 10 条，第 1 页

编号 / 商品	类别 / 编码	售价 / 上架	在架 / 已订 / 可售	维护
#11 拾光钥匙扣	文创 SP-KEY-005	12.0 / 已上架	18 / 0 / 18	售价 12.0 已上架 确认定价及上下架
#10 数据建模入门	图书 9787040000003	58.0 / 已上架	5 / 0 / 5	售价 58.0 已上架 确认定价及上下架
#9 拾光保温杯	文创 SP-CUP-004	36.0 / 已上架	5 / 0 / 5	售价 36.0 已上架 确认定价及上下架
#8 SQL Server 实战	图书 9787111000002	75.0 / 已上架	10 / 0 / 10	售价 75.0 已上架 确认定价及上下架
#7 拾光便签本	文创 SP-NOTE-003	29.0 / 未上架	0 / 0 / 0	售价 29.0 未上架 确认定价及上下架
#6 数据库系统概论	图书 9787300000001	未定价 / 未上架	0 / 0 / 0	售价 未上架 确认定价及上下架
#4 拾光书签	文创 SP-MARK-002	6.0 / 已上架	19 / 0 / 19	售价 6.0 已上架 确认定价及上下架
#3 拾光帆布袋	文创 SP-BAG-001	19.0 / 已上架	10 / 0 / 10	售价 19.0 已上架 确认定价及上下架
#2 百年孤独	图书 9787544253994	49.0 / 已上架	0 / 0 / 0	售价 49.0 已上架 确认定价及上下架
#1 活着	图书 9787506365437	39.0 / 已上架	6 / 0 / 6	售价 39.0 已上架 确认定价及上下架

拾光书店 · 单门店经营

> 图 12 | 日期/库/端口：2026-11-09，ShiguangBookstoreWeek7Shots20261109，5097 | 店长·定价与上下架 | 前置：商品 10 件（截图时新样品尚未创建） | 操作：打开定价页 | 预期：逐行改价/上下架 | 实际：列表可编辑



> 图 13 | 日期/库/端口：2026-11-09，ShiguangBookstoreWeek7Shots20261109，5097 | 收银员·会员开卡预览 | 前置：新号 13900000088 | 操作：银卡/新办/预览 | 预期：应收 ¥20.00 | 实际：应收 ¥20.00

结果层（13）



图 14 | 日期/库/端口：2026-11-09，ShiguangBookstoreWeek7Shots20261109，5097 | 库管·采购收货 | 前置：W7P…01 已付款 | 操作：整单收货 | 预期：状态已收货、库存 +2 | 实际：状态已收货、金额 ¥10.0000（库存 10→12 见数据库）



图 15 | 日期/库/端口：2026-11-09，ShiguangBookstoreWeek7Shots20261109，5097 | 收银员·销售凭证 | 前置：1 件 ¥19.00、银卡 0.95 | 操作：确认收款 | 预期：实收 ¥18.05、得 18 分 | 实际：W7S…03 实收 18.05



图 16 | 日期/库/端口：2026-11-09，ShiguangBookstoreWeek7Shots20261109，5097 | 收银员·取货凭证 | 前置：预订 1 件 | 操作：核验→确认交付 | 预期：生成销售、预订已取 | 实际：销售 W7S…02 ¥12.00



图 17 | 日期/库/端口：2026-11-09，ShiguangBookstoreWeek7Shots20261109，5097 | 收银员·退款凭证 | 前置：W7S…03 | 操作：退 1 件 | 预期：退款 ¥18.05、全退 | 实际：退款 18.05



图 18 | 日期/库/端口：2026-11-09，ShiguangBookstoreWeek7Shots20261109，5097 | 库管·回收后 | 前置：1 件待回收 | 操作：确认回收 | 预期：待回收清空、库存 +1 | 实际：已回收

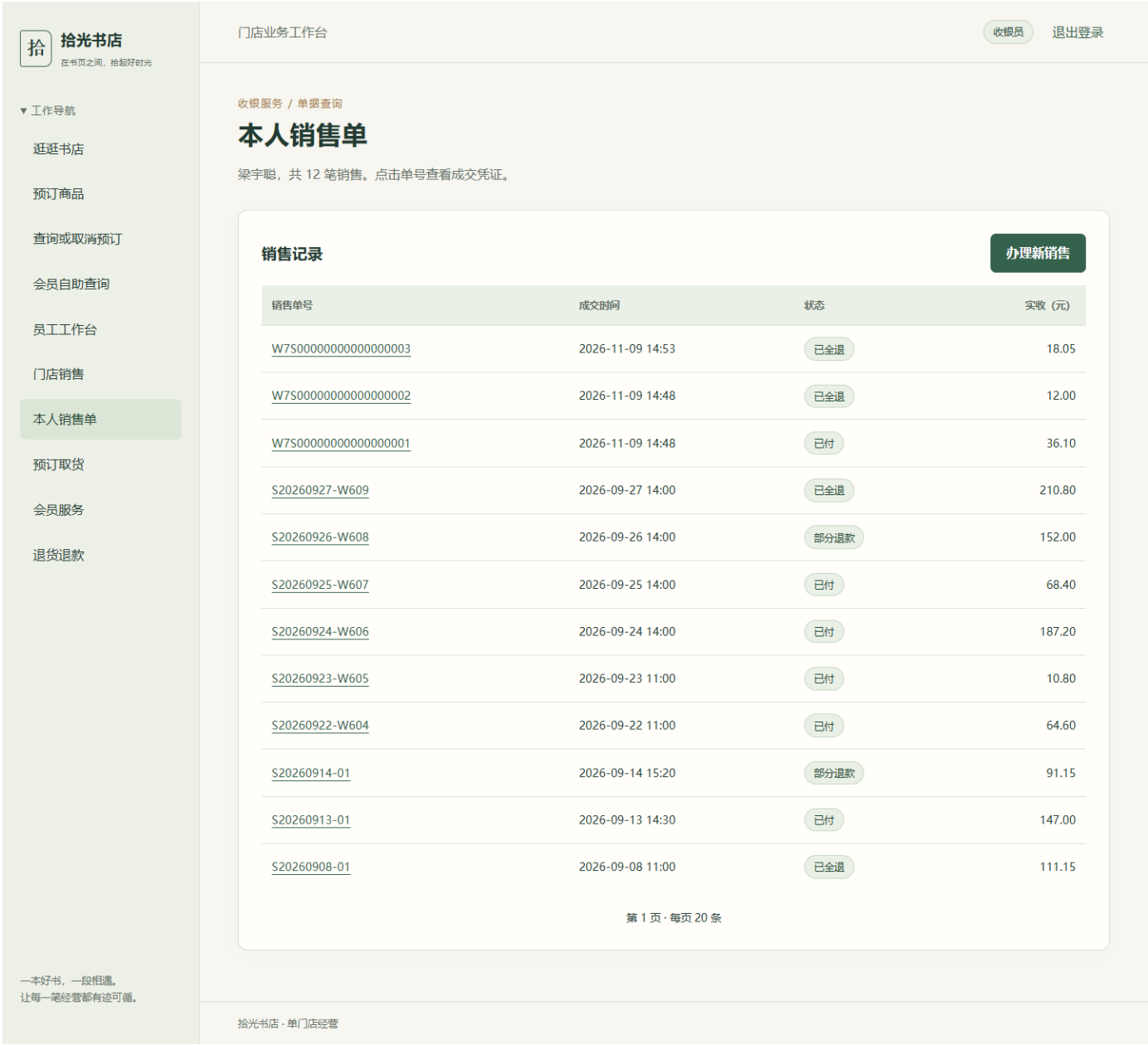


图 19｜日期/库/端口：2026-11-09，ShiguangBookstoreWeek7Shots20261109，5097｜收银员·全退状态｜前置：W7S…03 已退｜操作：打开本人销售单｜预期：状态已全退｜实际：已全退



退货回收

只减少可售量，不能消耗已订量；提交后写入库存流水。

商品编号

报损数量

原因

确认登记报损

记录列表

共 36 条，第 1 页

流水 / 商品	类型 / 数量	来源采购 / 销售	原因 / 经办人 / 时间
#36 / 商品#4	损坏 / -1	采购#— / 销售#— / 退货明细#—	截图报损 / 13800000002 / 2026-11-09 14:50
#35 / 商品#11	退货 / 1	采购#— / 销售#— / 退货明细#8	— / 13800000002 / 2026-11-09 14:50
#34 / 商品#11	卖出 / -1	采购#— / 销售#12 / 退货明细#—	— / 13800000003 / 2026-11-09 14:48
#33 / 商品#3	卖出 / -2	采购#— / 销售#11 / 退货明细#—	— / 13800000003 / 2026-11-09 14:48
#32 / 商品#3	购入 / 2	采购#11 / 销售#— / 退货明细#—	— / 13800000002 / 2026-11-09 14:48
#31 / 商品#9	退货 / 2	采购#— / 销售#— / 退货明细#7	— / 13800000002 / 2026-09-29 10:06
#30 / 商品#8	退货 / 1	采购#— / 销售#— / 退货明细#6	— / 13800000002 / 2026-09-29 10:05
#29 / 商品#8	退货 / 1	采购#— / 销售#— / 退货明细#5	— / 13800000002 / 2026-09-28 11:05
#28 / 商品#11	退货 / 1	采购#— / 销售#— / 退货明细#4	— / 13800000002 / 2026-09-28 10:06
#27 / 商品#10	退货 / 1	采购#— / 销售#— / 退货明细#3	— / 13800000002 / 2026-09-28 10:05
#26 / 商品#9	卖出 / -2	采购#— / 销售#10 / 退货明细#—	— / 13800000003 / 2026-09-27 14:01
#25 / 商品#8	卖出 / -2	采购#— / 销售#10 / 退货明细#—	— / 13800000003 / 2026-09-27 14:00
#24 / 商品#11	卖出 / -3	采购#— / 销售#9 / 退货明细#—	— / 13800000003 / 2026-09-26 14:01
#23 / 商品#10	卖出 / -2	采购#— / 销售#9 / 退货明细#—	— / 13800000003 / 2026-09-26 14:00
#22 / 商品#8	卖出 / -1	采购#— / 销售#8 / 退货明细#—	— / 13800000003 / 2026-09-25 14:00
#21 / 商品#9	卖出 / -2	采购#— / 销售#7 / 退货明细#—	— / 13800000003 / 2026-09-24 14:01
#20 / 商品#8	卖出 / -2	采购#— / 销售#7 / 退货明细#—	— / 13800000003 / 2026-09-24 14:00
#19 / 商品#11	卖出 / -1	采购#— / 销售#6 / 退货明细#—	— / 13800000003 / 2026-09-23 11:00
#18 / 商品#8	卖出 / -1	采购#— / 销售#5 / 退货明细#—	— / 13800000003 / 2026-09-22 11:00
#17 / 商品#8	购入 / 4	采购#10 / 销售#— / 退货明细#—	— / 13800000002 / 2026-09-21 10:44

下一页

一本好书，一段相遇。
让每一笔经营都有迹可循。

拾光书店 · 单门店经营

图 20 | 日期/库/端口：2026-11-09，ShiguangBookstoreWeek7Shots20261109，5097 | 库管·报损 | 前置：商品 4 有库存 | 操作：报损 1 件、填原因 | 预期：库存 −1、写流水 | 实际：已登记

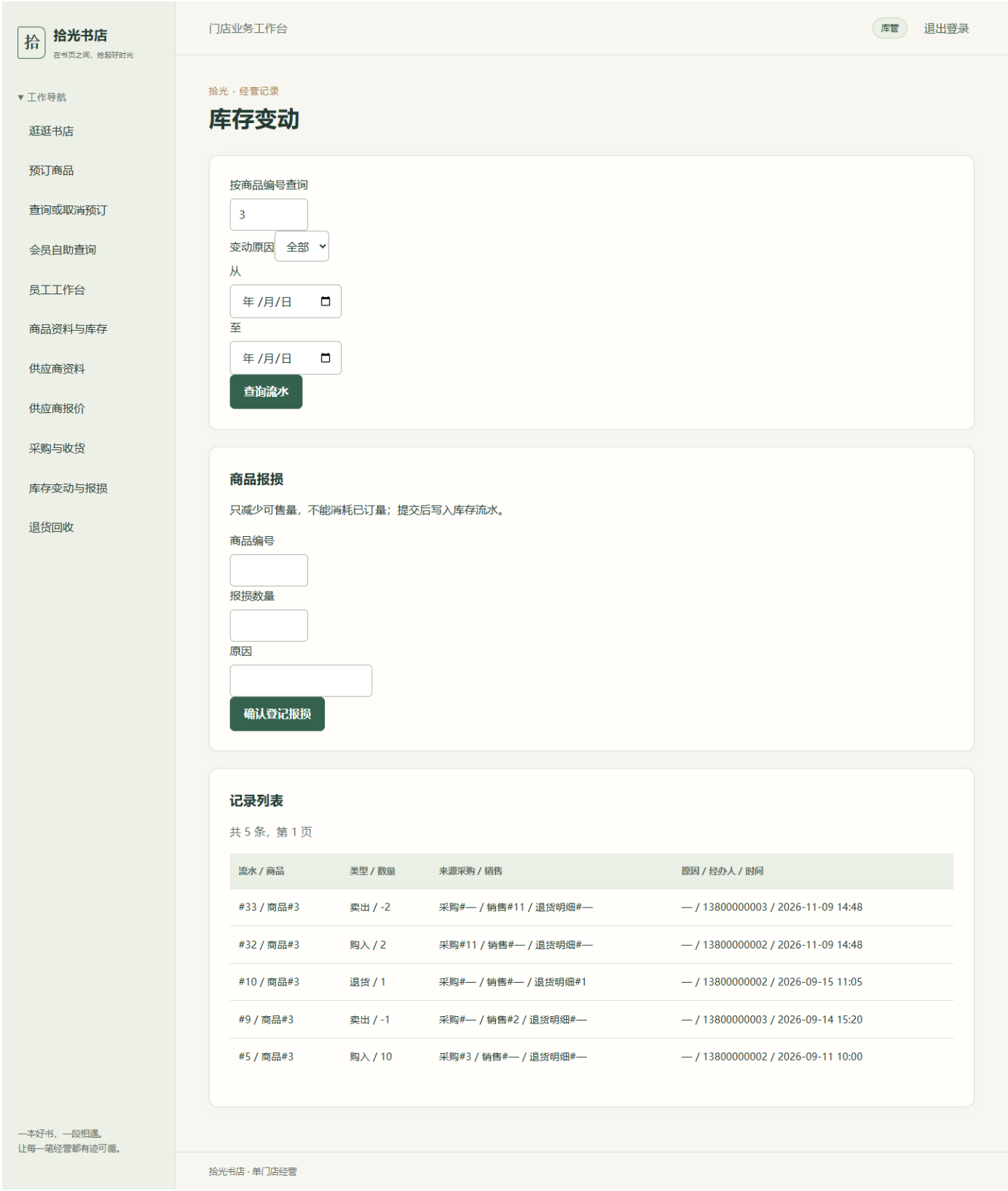


图 21｜日期/库/端口：2026-11-09，ShiguangBookstoreWeek7Shots20261109，5097｜库管·库存流水｜前置：商品 3 有采购/销售/回收流水｜操作：按商品筛选｜预期：流水与来源可见｜实际：200



图 22 | 日期/库/端口：2026-11-09，ShiguangBookstoreWeek7Shots20261109，5097 | 顾客·会员自助 | 前置：新会员凭证 | 操作：联系方式 + 凭证 | 预期：显示本人积分/单据 | 实际：查询成功



图 23 | 日期/库/端口：2026-11-09，ShiguangBookstoreWeek7Shots20261109，5097 | 店长·卡参数 | 前置：两档卡 | 操作：打开卡参数 | 预期：金/银费率 | 实际：50/0.90、20/0.95

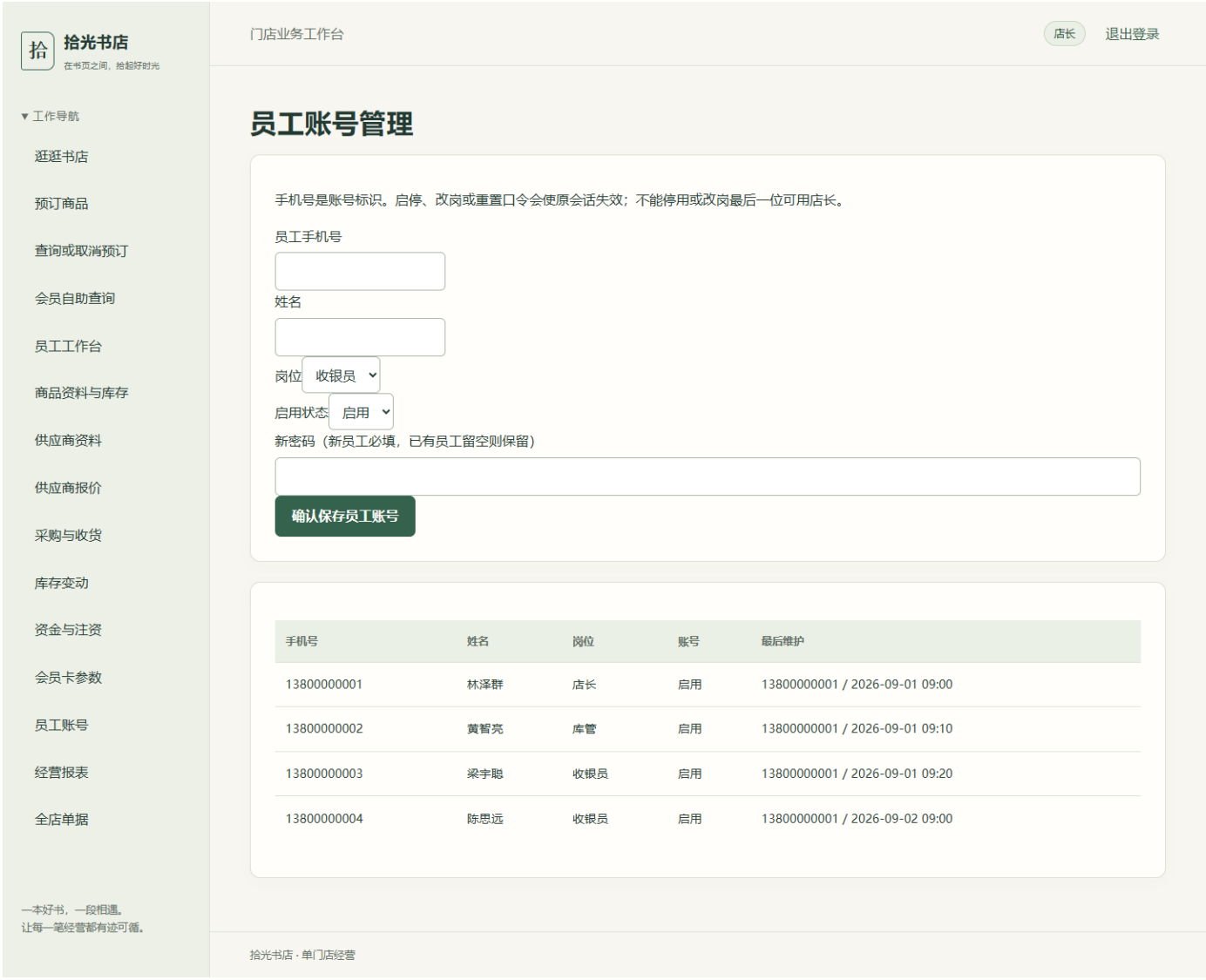


图 24 | 日期/库/端口：2026-11-09，ShiguangBookstoreWeek7Shots20261109，5097 | 店长·员工账号 | 前置：4 名员工 | 操作：打开员工页 | 预期：岗位/状态 | 实际：4 条记录

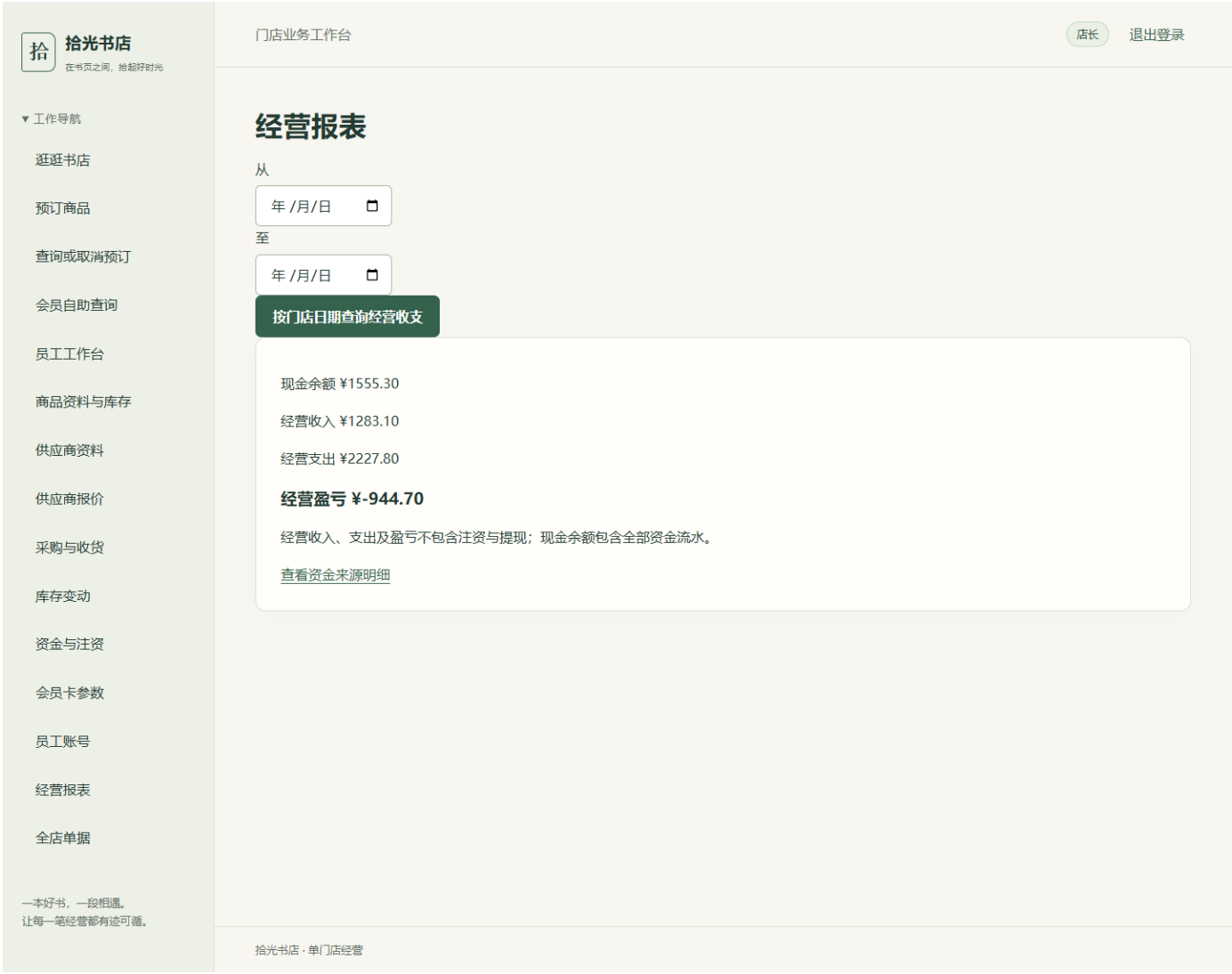


图 25 | 日期/库/端口：2026-11-09，ShiguangBookstoreWeek7Shots20261109，5097 | 店长·经营报表 | 前置：演示数据 | 操作：打开报表 | 预期：收入/支出/盈亏/现金 | 实际：现金 ¥1555.30、收入 ¥1283.10、支出 ¥2227.80、盈亏 −¥944.70

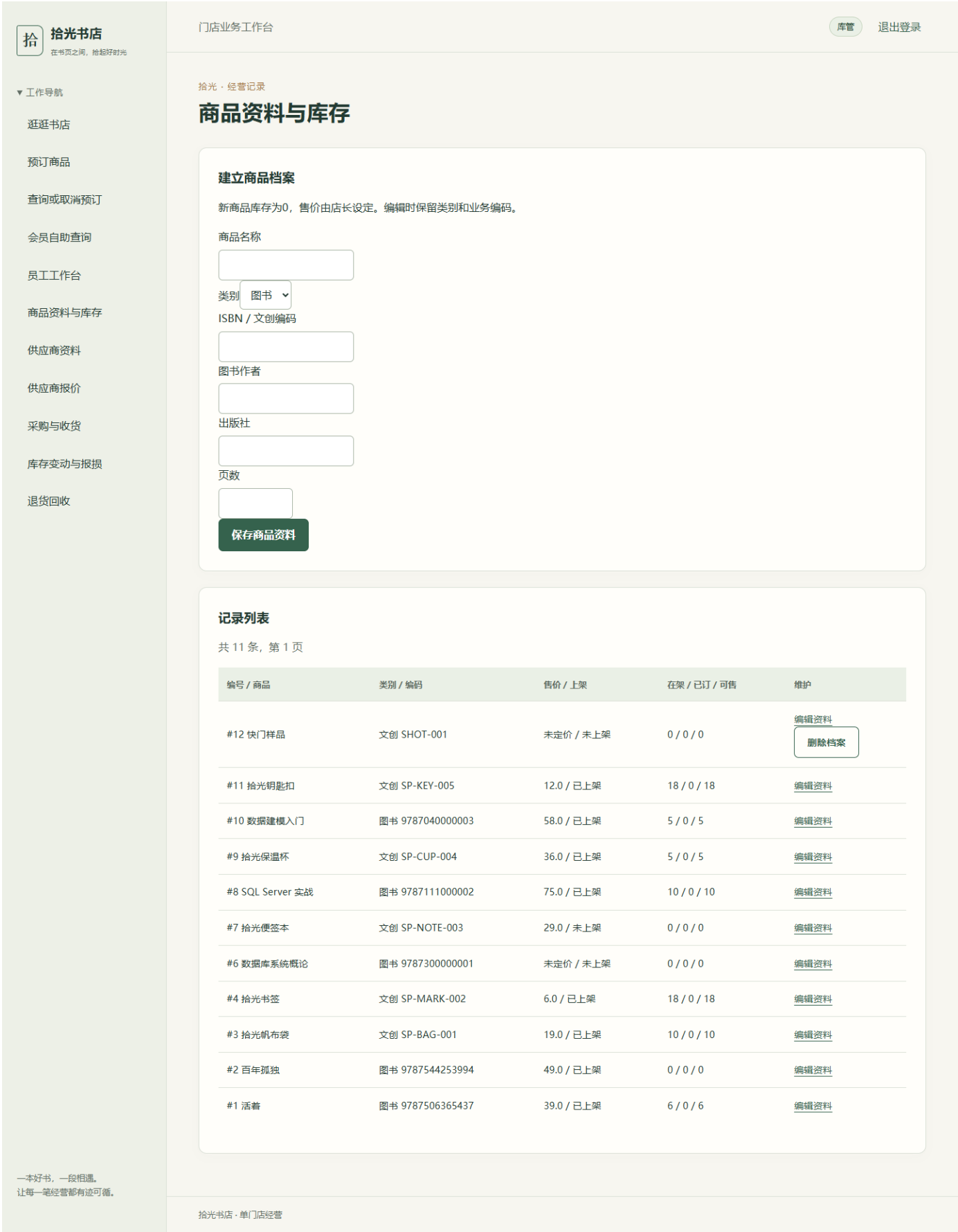


图 26 | 日期/库/端口：2026-11-09，ShiguangBookstoreWeek7Shots20261109，5097 | 库管·删除入口 | 前置：SHOT-001 三无，其余有库存、在架或有引用 | 操作：打开商品列表 | 预期：仅三无显示删除 | 实际：仅 1 行有按钮

5.5 SQL 对账

对账项	实际值
采购	商品 3 采购 2 件，单价 ¥5.00，已收货，库存 +2

对账项	实际值
销售	商品 3 售 1 件，原价 ¥19.00，实收 ¥18.05，库存 −1
退款/回收	退款 ¥18.05，积分回滚 18；回收 1 件，库存 +1
删除	11 个商品中仅三无档案可删；删除后子类编码可复用

5.6 截图与证据索引

正文截图路径：`docs/reports/assets/web-v1.0/`（`fig-01`—`fig-31`；图 32 因无安全触发手段未截图）。截图采集自 2026-11-09 的 `ShiguangBookstoreWeek7Shots20261109`；运行与测试的结构化结果仍见 `db/results/week-7/stage-report-20261107/`（`runtime-results.json`、`browser-results.json`、`database-checks.json`）。演示账号与手机号为虚构数据；截图未统一打码，正式外发前需遮盖手机号与凭证。

6 异常与测试结果

6.1 测试分层与清单

文件	用例数	主要类型	验证内容
`test_sales.py`	35	单元 + 真实事务	预览/确认、签名、幂等、并发、过期、快照
`test_entry_database.py`	14	真实库结构	外码、CHECK、受限账户
`test_operations.py`	13	真实库 + HTTP	采购、报损、付款/收货、资金、回滚
`test_web.py`	12	HTTP 契约（内存 DAO）	错误契约、分页、CSRF、日志脱敏、500
`test_auth.py`	11	单测	登录、会话版本、口令、登出
`test_runner.py`	11	单测	setup/doctor/test/verify/stop
`test_members.py`	9	真实库	开卡/升级/改号、闰年、最后店长
`test_application_baseline.py`	5	真实库基线	应用对象与授权
`test_new_workflows.py`	4	真实库/HTTP	预订重试、取货绑定、退货输入
`test_returns.py`	3	真实库	全退/部分退、分摊、积分回滚
`test_shop.py`	2	单测/HTTP	顾客目录与预订

口径：119 = 49 项无库单测 + 70 项真实库测试；另有 16 个浏览器节点与 22 个结构反例，不重复计入 119。

6.2 用例矩阵与追踪

类别	覆盖点	用例/脚本	证据
功能	销售/取货/退货/采购/会员	`test_sales`、`test_returns`、`test_operations`	测试名 + 输出
权限	角色、六连接、字段可见性	`test_auth`、`test_web`、SQL 角色用例	断言 + 403 截图
异常	400/401/403/404/409/503/500	`test_web`、故障注入	响应/日志
并发	末件、重复请求、积分	`test_sales` 并发类	只成交 1 笔
故障	事务回滚、连接失败	`test_operations`、`test_web`	数据回基线
SQL 结构	外键/CHECK/唯一索引	`db/tests/`、`regression-negative`	原始输出
浏览器	四角色与拒绝访问	`browser_workflows.py`	16 节点 JSON

能力（B 编号）	实现	测试用例	证据
B1 商品建档、定价、上下架	`/goods`、`/management/goods`	`test_operations`	图 10、图 12
B2 采购申请、审批、付款、收货	`/purchases`、`/operations/*`	`test_operations`	图 8、图 9、图 14
B3 报损	`/inventory`	`test_operations`	图 20
B4 门店销售	`/sales/new`、`/sales`	`test_sales`	图 7、图 15
B5 在线预订与取消	`/shop/reservations/*`	`test_sales`、`test_shop`	图 6
B6 到店取货	`/pickups`	`test_sales`	图 16

能力（B 编号）	实现	测试用例	证据
B7 退货与回收	`/returns/*`、`/return-recovery`	`test_returns`	图 17、图 18、图 19
B8 会员办理、升级、改号	`/members`、`/members/contact`	`test_members`	图 13、图 22
B9 卡档配置	`/management/cards`	`test_members`	图 23
B10 员工与账号	`/management/employees`	`test_members`	图 24
B11 商品与库存查询	`/goods`、`/inventory`	`test_shop`、`test_operations`	图 2、图 21
B12 库存流水查询	`/inventory` 筛选	`test_operations`	图 21
B13 单据与自助查询	`/sales/<no>`、`/shop/member`	`test_sales`、`test_shop`	图 15、图 16、图 22
B14 资金登记（注资/提现/付款）	`/management/finance`、`/operations/*`	`test_operations`	图 9
B15 盈亏与经营查询	`/management/reports`	`test_members`	图 25

> 课程要求中的登录、四层结构、四类对象 CRUD、五类失败与账目一致性，分别落在 B1—B15 与 §6.4 的异常矩阵中；逐项证据见上表与 §5.4 截图。

6.3 错误码映射

HTTP	业务码示例	场景
400	`52101`、`52301`、`52501`	参数、数量、格式、分页超限
401	认证	未登录、会话失效
403	`52003` / CSRF	岗位不足、CSRF 无效
404	`52108`、`52304`、`52504`	单据/记录不存在
409	`52103`—`52107`、`52302`—`52309`、`2601/2627/547`	规则冲突、约束冲突
503	连接失败	数据库不可用
500	未预期/事务失败	注入故障、未捕获异常

以上以 `app/dao.py` 映射为准。

6.4 异常矩阵

#	类别	触发方式	实际状态	错误码	可见信息/恢复
1	参数/格式/范围	页码 0、非数字、超长	400	参数校验	字段级提示
2	未登录	匿名访问工作台	401	认证	跳登录
3	会话失效	改岗后旧会话	401	认证	要求重新登录
4	岗位不足	收银访问店长页	403	`52003`	统一“无权限”
5	CSRF 缺失/错误	去掉/篡改 token	403	CSRF	刷新重试
6	不存在/防枚举	随机单号	404/同形 403	`52304` 等	不泄露存在性
7	业务规则冲突	库存不足、超退、预览过期	409	`52xxx`	重新预览
8	约束冲突	重复编码、非法外码	409	`2601/2627/547`	不显示约束名
9	连接失败	禁用顾客登录并断会话	503	连接失败	原页重试
10	事务失败	资金写入点注入故障	500	未预期/事务	无部分写入
11	方法与媒体类型	只读路由 POST、错误 Content-Type	405/415	协议层	不泄露实现
12	幂等重放	同键同内容重复提交	200/303	非错误	返回原结果

> 表中“实际状态”为 §6.1 对应用例的实测结果；请求编号与响应片段见 §6.5 与 `runtime-results.json`。

6.5 异常截图与证据

5 张异常截图可安全构造；500 无安全触发手段，保留图 32 的说明，不伪造截图。

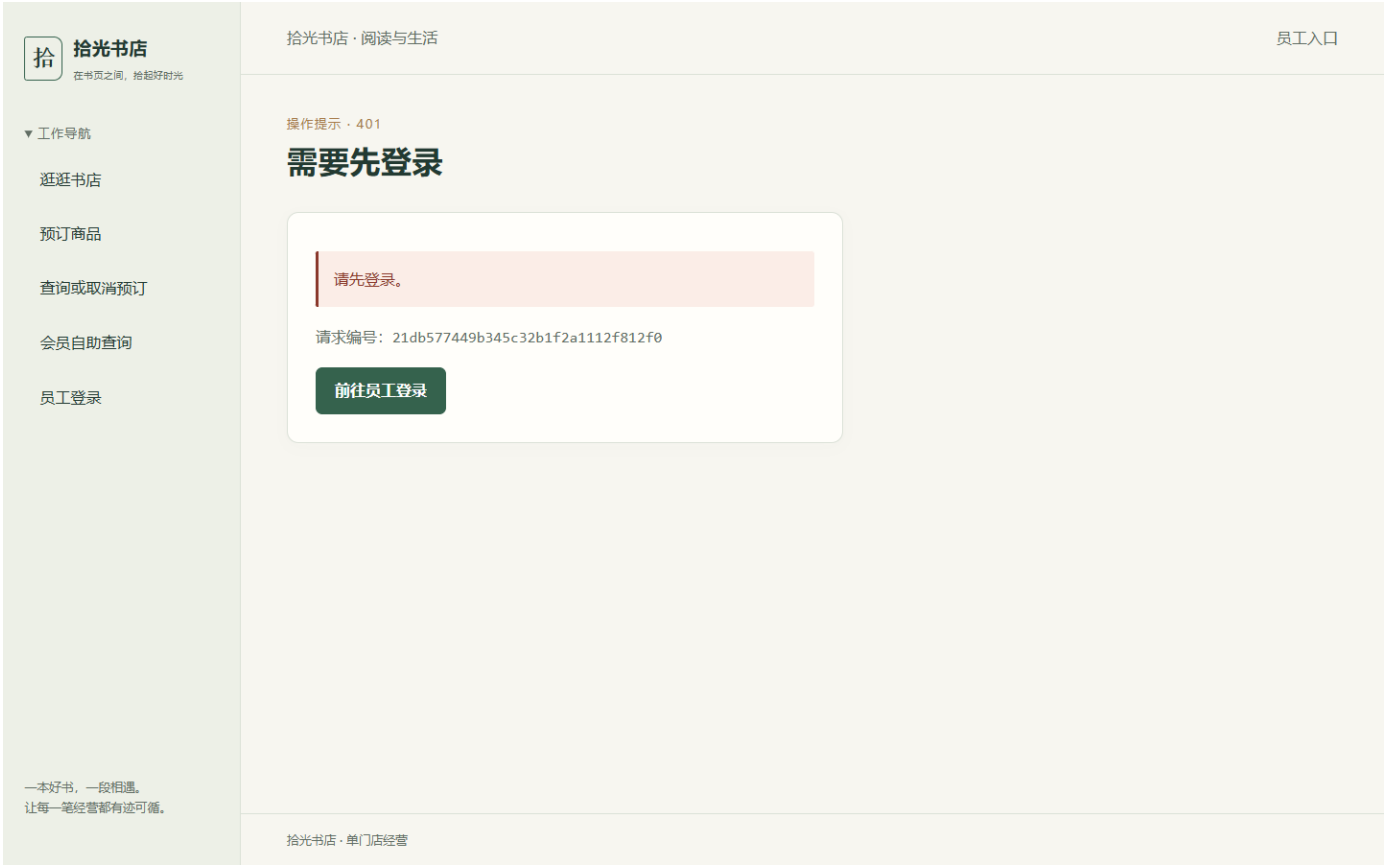


图 27 | 公共·401 | 前置：匿名 | 操作：访问 `/workspace` | 预期：401 | 实际：401

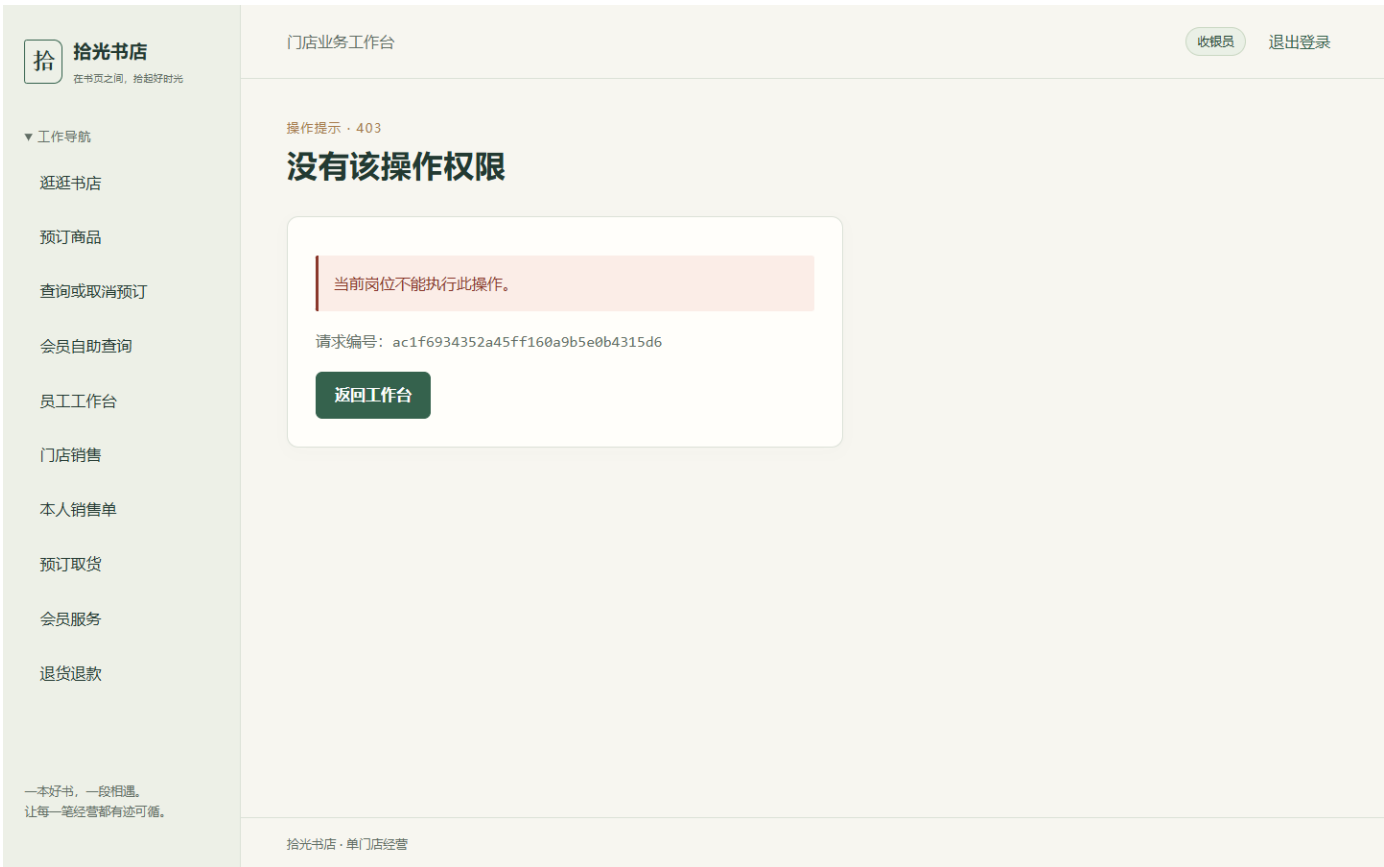


图 28 | 收银员·403 | 前置：收银登录 | 操作：访问 `/management/finance` | 预期：403 | 实际：403

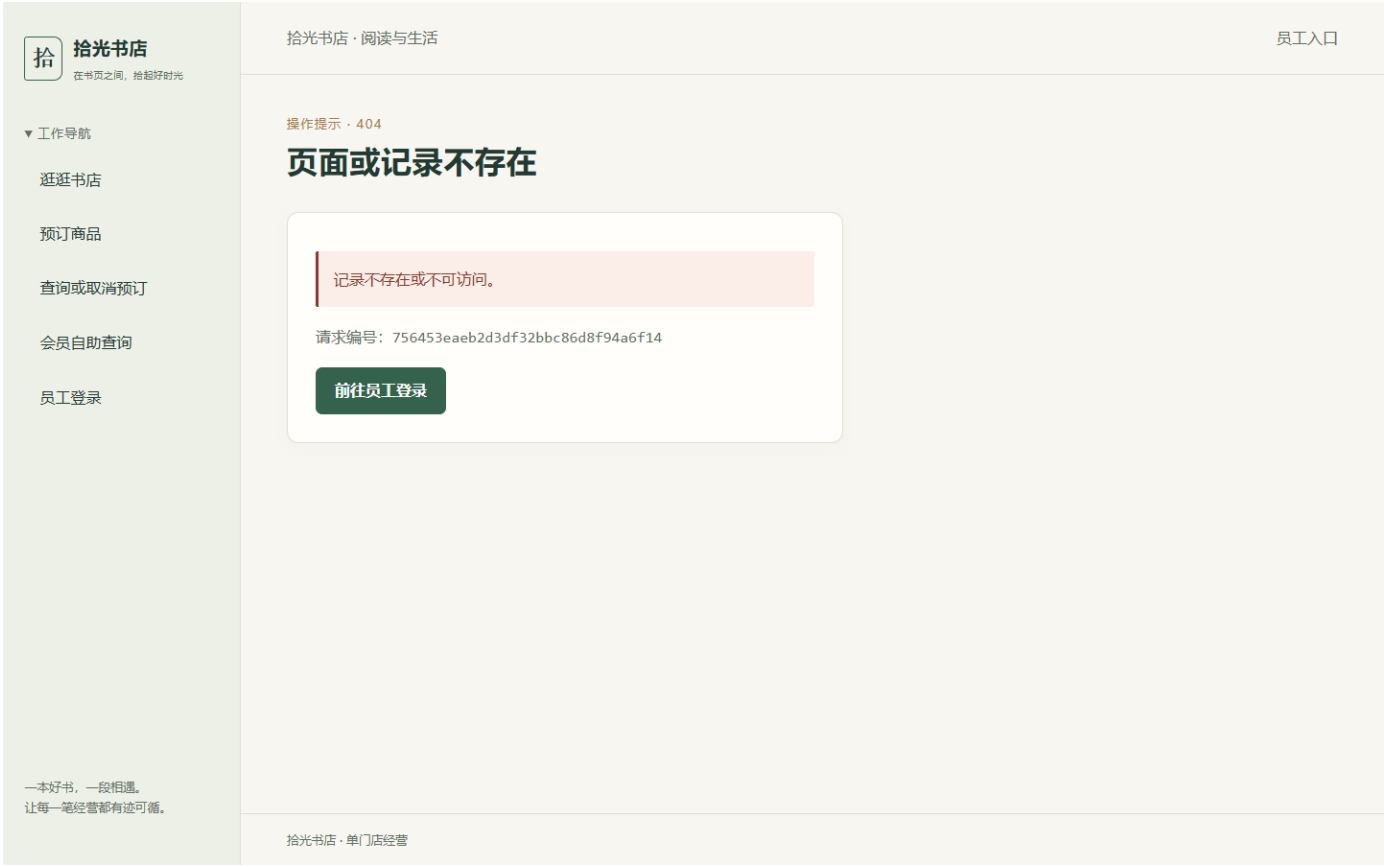


图 29 | 公共·404 | 前置：无 | 操作：访问 /no-such-page | 预期：404 | 实际：404



图 30 | 收银员·409 | 前置：W7S…01 2 件未退 | 操作：退 3 件 | 预期：409 | 实际：409



图 31 | 公共·503 | 前置：禁用顾客登录并断会话 | 操作：访问 `/shop` | 预期：503 + 重试 | 实际：503

图 32（无安全触发手段，未截图）

图 32 | 公共·500 | 该状态是应用未捕获异常的兜底，正常业务路径不会触发；本轮没有可安全构造的触发手段，因此不提供截图、也不伪造页面。其行为由 `tests/test_web.py` 的 500 用例断言：统一提示、不泄露异常值、日志保留堆栈位置。

6.6 数据隔离与可重复

测试只在专用副本运行，六组连接由配置生成；`skip>0` 视为环境未就绪，不记通过。每例清理自建单据，样例与指纹恢复；并发用例连续跑 3 次一致才算通过。

6.7 不泄露、日志与恢复

1. HTML 错误页与 JSON 错误体均不出现 SQL、表名、约束名、连接串、堆栈；
2. 同一 `request_id` 能查到动作、岗位、状态、错误码、结果、耗时，且不含口令与完整凭证；
3. 503 恢复后重试成功；409 重新预览后成功；事务失败后数据回到基线。

6.8 缺陷—修复—复测

#	现象	发现方式	修复	复测
1	索引数量写死 6，新库 setup 失败	新副本 setup	按名称与启用状态校验	新库 29 步 PASS；改名报缺失
2	CRLF 转换导致历史指纹失败	换行审计	`.gitattributes` 固定检出	三种 autocrlf 均 PASS
3	删除商品后子类残留，编码不可复用	删除后重建	同事务清理 book/toy	删除后重建成功

6.9 未覆盖与 flaky 规则

未覆盖：500 的原始响应与日志片段、另机复现、键盘 Tab 与打印；并发更高压力未测。并发用例连续 3 次一致才算通过，不用重试掩盖失败。

7 实验总结

本阶段把已冻结的模型落实到四类角色的 Web 操作：顾客预订与自助查询，收银销售、取货、会员与退款，库管商品、采购、收货、报损与回收，店长定价、审批、员工、卡参数与经营查询。采购付款与实物收货、退款与实物回收各自留痕，资金与库存可独立对账。

实测发现：约束保证记录形状，跨表一致性仍需业务事务；正常下单只能证明功能可用，末件竞争、重复请求与中途故障才能检验事务设计。当前销售草稿仍使用单进程内存，部分只读请求在鉴权后直接调用 DAO；另机复现已有用户确认，原始输出待补。分工：黄智亮（复核与修复，已签）、梁

宇聪（已签）、林泽群（待签）。

附录

- 运行证据：`db/results/week-7/stage-report-20261107/README.md`
- AI 使用记录：`docs/ai-usage-log.md`
- 分工与签收：`docs/reports/team-division-v1.0.md`
- 第 5—6 周基线：`ER/`、`docs/reports/report-week-6.md`、`docs/reviews/review-week-6.md`